

BinX Tech

Backend .NET Internship

Cardiac Patient Monitoring System

Authorization Matrix

Role-Based • Policy-Based • Resource-Based Authorization

Project Authorization Reference

Section 1 • Overview

This document defines the planned authorization rules for the Cardiac Patient Monitoring System.

The system currently uses three application roles:

• Admin • Doctor • Patient

Authorization is designed in three levels:

1. Role-Based Authorization — straightforward role permissions.
2. Policy-Based Authorization — reusable business requirements such as minimum age.
3. Resource-Based Authorization — ownership and relationship checks for specific resources.

Design note: These rules are project design decisions intended to guide implementation and keep authorization behavior consistent across the API.

Section 2 • Roles

Role	Responsibility
Admin	Full system administration and management of system resources.
Doctor	Clinical operations and access to patient-related data according to authorization and ownership rules.
Patient	Access to the patient's own profile and health-related resources, subject to ownership and business rules.

Section 3 • Role-Based Authorization Matrix

Legend: **■** Allowed **■** Not allowed ***** Requires an additional ownership/resource check.

Resource / Action	Admin	Doctor	Patient
View Doctors	■	■	■
Create Doctor	■	■	■
Update Doctor	■	■	■
Delete Doctor	■	■	■
View Patients	■	■*	■*
Create Patient	■	■	■
Update Patient	■	■*	■*
Delete Patient	■	■	■
View Vital Signs	■	■*	■*
Create Vital Sign	■	■*	■*
Update Vital Sign	■	■*	■
Delete Vital Sign	■	■	■
View Medications	■	■	■
Create Medication	■	■	■
Update Medication	■	■	■
Delete Medication	■	■	■
View Patient Medications	■	■*	■*
Create Patient Medication	■	■*	■
Update Patient Medication	■	■*	■
Delete Patient Medication	■	■	■
View Appointments	■	■*	■*
Create Appointment	■	■*	■*

Resource / Action	Admin	Doctor	Patient
Update Appointment	■	■*	■*
Delete Appointment	■	■	■

Section 4 • Role-Based Authorization

Role-based rules should be implemented with ASP.NET Core authorization attributes where the rule is simple and does not depend on a specific resource.

```
[Authorize]

[Authorize(Roles = "Doctor")]

[Authorize(Roles = "Admin")]
```

Role checks answer: What type of user is making this request? They do not, by themselves, answer whether the user owns or is allowed to access a particular resource.

Section 5 • Resource Ownership

5.1 Doctor → Patient

A doctor should not automatically have access to every patient merely because the user has the Doctor role.

```
Doctor
|
+-- Assigned Patient A → Allowed
+-- Assigned Patient B → Allowed
+-- Unrelated Patient C → Forbidden
```

The API should verify the relationship between the authenticated doctor and the requested patient/resource.

This rule is expected to apply to patient-related resources such as Patients, Vital Signs, Patient Medications, and Appointments where the underlying data relationship supports the check.

5.2 Patient → Own Data

```
Patient A
|
+-- Patient A vital signs → Allowed
+-- Patient A medications → Allowed
+-- Patient B vital signs → Forbidden
```

Ownership checks should be performed using the authenticated user's identity and the resource's patient relationship.

Section 6 • Age Requirement

Age is treated as a business requirement, not as a role.

The planned rule is: certain protected operations may require the authenticated user to be at least 18 years old.

This should not create an additional role such as Adult.

```
Role
■■■ Admin
■■■ Doctor
■■■ Patient

Business requirement
■■■ Age >= 18
```

This requirement is a candidate for Policy-Based Authorization.

```
[Authorize(Policy = "AdultOnly")]
```

The exact endpoints requiring this policy should be decided when the corresponding business operation is implemented.

Section 7 • Authorization Levels

The project will use the simplest authorization mechanism that correctly expresses each rule.

Level 1 — Role-Based Authorization

Use when the rule depends only on the user's role.

```
[Authorize(Roles = "Doctor")]
```

Level 2 — Policy-Based Authorization

Use when the rule represents a reusable business requirement. Example: Age >= 18.

Level 3 — Resource-Based Authorization

Use when authorization depends on the relationship between the authenticated user and a specific resource, such as Doctor → assigned Patient or Patient → own data.

This can be implemented using ASP.NET Core authorization services and custom authorization handlers when needed.

Section 8 • HTTP Authorization Outcomes

Status	Meaning
401 Unauthorized	The request does not contain valid authentication credentials.
403 Forbidden	The user is authenticated but does not have permission to perform the requested operation.

No JWT
→ 401 Unauthorized

Valid JWT + wrong role
→ 403 Forbidden

Valid Doctor JWT + unrelated Patient resource
→ 403 Forbidden

Section 9 • Implementation Strategy

Completed

- ASP.NET Core Identity
• User registration
• JWT authentication
• JWT validation
• Role claims in JWT
• Admin, Doctor, and Patient roles
• Role-based authorization foundation
• Authorization middleware

Next

1. Apply role rules to the remaining controllers.
2. Add and test resource ownership rules.
3. Introduce the age requirement where a real business operation requires it.
4. Add policy-based authorization for reusable requirements.
5. Add resource-based authorization handlers for ownership checks.
6. Test 401 and 403 scenarios through Postman/Swagger.

Section 10 • Testing Requirements

Each authorization rule should be tested with at least:

- Valid authorized user → expected success.
• Unauthenticated request → 401 Unauthorized.
• Authenticated user with insufficient role → 403 Forbidden.
• Authenticated user with the correct role but without resource ownership → 403 Forbidden.
• Valid owner/authorized user → expected success.

Authorization tests should be documented alongside the relevant API/Postman tests.

Section 11 • Future Authorization Rules

The matrix is intentionally extensible.

Future rules may include:

- Doctor-specific patient assignments.
• Patient ownership of health records.
• Appointment ownership/assignment.
• Additional business requirements expressed as policies.
• More granular permissions if the system grows beyond the current three-role model.

New rules should be documented here before implementation whenever possible.